

Table of Contents

Introduction

1.1 Introduction

1.2 Objective

1.3 Scope of Testing

Executive Summary

2.1 Key Vulnerabilities Identified

2.2 Risk Overview

Approach & Methodology

3.1 Methodology

3.2 Tools Used

Information Gathering & Network Scanning

4.1 Attacker Machine Identification

4.2 Network Discovery

4.3 Target Availability Verification (Ping)

Port Scanning & Service Enumeration

5.1 Nmap Scan Results

5.2 Port 22 – SSH Analysis

5.3 Port 80 – HTTP Analysis

5.4 Operating System Detection

Web Enumeration

6.1 Directory Enumeration using

Gobuster

6.2 Enumeration Results

6.3 Analysis of Discovered Paths

Web Application Analysis

7.1 Application Overview

7.2 Login and Registration Functionality

7.3 Link Submission Feature

Exploitation

8.1 Reverse Tabnabbing Vulnerability

8.2 Cloning the Legitimate Webpage

8.3 Creating a Malicious Phishing Page

8.4 Sending Malicious Link / Credential

Harvesting

Initial Access

9.1 Obtaining User Credentials

9.2 SSH Access to Target Machine

Privilege Escalation

10.1 Enumeration of System Privileges

10.2 Discovery of Writable Python Script

Exploiting the Python Script

11.1 Analysis of the Scheduled Script

11.2 Code Injection into Python Script

11.3 Gaining Root Access

Post-Exploitation

12.1 System Enumeration as Root

12.2 Sensitive Data Access

12.3 Proof of System Compromise

Conclusion

Recommendations / Mitigation

References